ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens SIPROTEC 5 7UM85 Generator / Machine Protection Relay (IED) · Component type: **Embedded Device (EDR) - protective relay / IED** · Target SL = SL 3

Where to work	**DIGSI 5** (engineering tool) - Project tree › [device] › **Safety and security** (Operations safety & access control; Network access security) and **Hardware and protocols**; the on-device **HMI**; the browser **Web UI / Diagnostics Homepage**; the front **USB**; **Online › Security** (credential reset). PKI issued via **SICAM GridPass**.
Ports / paths	IEC 61850 MMS **TCP 102** (non-secure, default) or **TCP 3782** (SecureTLS per IEC 62351); DIGSI 5 over **TLS**; Web UI **HTTPS 443**; Syslog **UDP 514** (or Syslog-over-TLS); time sync **SNTP UDP 123** / IEEE 1588 PTP / IRIG-B; optional DNP3 **20000**, IEC 60870-5-104 **2404**, GOOSE/SV (L2). Connection password 8-24 chars, **empty by default**. Reset confirmation ID = **222222**.
Notes	EDR - protection relay (IED), SIPROTEC 5 7UM85 (generator/machine protection). Confirm firmware (RBAC needs V7.80+), fitted communication modules/protocols, and whether central RBAC (RADIUS/LDAP) or the device connection password is used. Security features per the C081 manual matching the installed version.
How to read	Each row = one SL-3 requirement with native DIGSI 5 step-by-step (exact tree path) + command-level external-tool steps. Default read-only. Scans authorized; any protocol fuzzing ISOLATED lab only - never on an in-service protection relay.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the **DIGSI 5 project archive (.dz5)** containing this relay + the device settings export (.dex5) **read from the IED**, the connection password / confirmation-IDs + per-interface RBAC, the CFC logic, firmware rev, and the fault/event records (COMTRADE) export.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	Verify authentication at every path. In DIGSI 5 open **Project tree › [device] › Safety and security › Operations safety and access control**: confirm either **RBAC** is activated (central user management via RADIUS/LDAP, V7.80+) or, if RBAC is off, that the **connection password** is set (8-24 chars; it is **empty by default** = open access). Confirm the HMI and Web UI require the same. Note: the connection password can only be initialized via the **front USB** or an Ethernet interface (over TLS). **Test:** in DIGSI 5, connect to the device - it must demand the connection password / certificate; a wrong password 5x is recorded in the security log. **Ext. tools:** `nmap -p 102,3782,443 <relay_ip>` (exposed MMS/secure-MMS/Web UI); DIGSI 5 connect w/o password -> refused; Wireshark `tls` (DIGSI auth handshake).	RBAC on OR connection password set (non-empty); HMI/Web require login; no unauthenticated access.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.2	Software process / device identification	Confirm unique identity and mutual authentication: the IEC 61850 **IED name** and IP per Ethernet module (Hardware and protocols); DIGSI 5 clients present a **client certificate** (customer CA); GOOSE/SV peers defined in the 61850 dataset config. **Ext. tools:** Wireshark filter `mms || goose` (IED name / peers); DIGSI 5 (Network access security › Trusted CA); `openssl s_client -connect <ip>:3782` (device MMS cert).	Unique, certificate-bound identities; peers defined.	
SR/CR 1.3	Account management	With central RBAC, users/roles are managed on the RADIUS/LDAP server - confirm least-privilege role mapping and that only authorized DIGSI 5 installations (client certs signed by your CA) may connect. With the connection-password model, confirm the password is controlled and rotated. Emergency-access accounts reviewed. **Ext. tools:** RADIUS/LDAP server (group/role export); DIGSI 5 (Network access security › Trusted CA list); credential-custody record.	Accounts managed/least-privilege (central or device); DIGSI trust controlled.	
SR/CR 1.4	Identifier management	Confirm unique user IDs (central or device) and a unique device identity (IEC 61850 IED name, IP per module, serial); no reuse across relays. **Ext. tools:** DIGSI 5 (IED name / module IPs); RADIUS/LDAP user list; device inventory.	Unique user and device identifiers; no reuse.	
SR/CR 1.5	Authenticator management	The connection password follows the **NERC-CIP** format (upper/lower/number/special) and DIGSI 5 verifies the 8-24 length. With central RBAC, password policy is enforced upstream (capture evidence). Rotate default/reset confirmation IDs. **Ext. tools:** DIGSI 5 (Operations safety - password rule); RADIUS/LDAP policy screenshot.	Strong connection password (8-24, NERC-CIP) or upstream policy; confirmation IDs non-default.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	In **Safety and security › Network access security** confirm the **Trusted CA** is your customer CA (not the default "SIPROTEC 5 trusted certificate authority"), so only DIGSI 5 clients with certs signed by your CA connect. For Secure MMS/Web UI, confirm device certs are CA-signed (CSR downloaded from the Web UI, signed by your CA, uploaded - or auto-enrolled via EST). PKI is issued via SICAM GridPass. **Ext. tools:** DIGSI 5 (Trusted CA config; Tools › Manage certificate authorities); `openssl s_client -connect <ip>:3782 | openssl x509 -noout -issuer -dates`.	Customer-CA trust enforced; device certs CA-signed/valid; Siemens default replaced.	
SR/CR 1.9	Strength of public key auth	Confirm certificate keys/algorithms are strong/current (no weak/expired); TLS on Secure MMS (3782), DIGSI, and Web UI uses current suites. **Ext. tools:** `testssl.sh https://<ip>` (Web UI); `openssl s_client -connect <ip>:3782` (suite/key size).	Strong, current crypto for certificate-based auth.	
SR/CR 1.10	Authenticator feedback	Confirm DIGSI 5, HMI, and Web UI obscure password/confirmation-ID entry (the connection-password field shows asterisks; entered twice to confirm). **Ext. tools:** Visual verification (screenshot masked field).	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The device records a wrong connection password in the **security log**; after **5 wrong attempts** it responds per the manual. With central RBAC, lockout is enforced upstream. Forward events to the SIEM. **Ext. tools:** DIGSI 5 (security log after failed attempts); Syslog/SIEM (failed-auth events via `nc -lu 514` listener during a test).	Failed logins limited and logged (device + upstream).	
SR/CR 1.12	System use notification	Confirm an approved use-notification where supported (Web UI/HMI login notice); enforce it on the DIGSI 5 engineering workstation (GPO) as well. **Ext. tools:** HMI/Web UI banner screenshot; EWS `gpresult /h gp.html` (legalnoticetext).	Use notice presented at device interfaces/EWS.	
SR 1.13	Access via untrusted networks	Confirm the relay's station/engineering Ethernet is reachable only from the trusted substation zone behind the station firewall; remote DIGSI 5 access only via VPN/jump host. **Test:** from an untrusted VLAN, scan the relay - it must not answer. **Ext. tools:** `nmap -Pn -p 102,3782,443,20000,2404 <relay_ip>` from the untrusted side (expect filtered); firewall/ACL rule export.	Untrusted-network access denied; remote via VPN/jump host.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm least privilege. In **Safety and security › Network access security** each interface is set to **No access / Read-only / Read and write** - confirm engineering interfaces are not left Read-write to everyone. If RBAC is off, confirm **Confirmation IDs** gate safety-critical operations (switching, setting changes) so a read-only user cannot operate or reconfigure. **Test:** as a read-only user (or without the confirmation ID) attempt a switching command / setting change -> refused. **Ext. tools:** DIGSI 5 (Network access security levels + Confirmation IDs screenshot); read-only negative test (isolated).	Per-interface access levels + confirmation IDs enforce least privilege; negative test confirms denial.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the DIGSI 5 laptop and the front USB; removable-media policy on the engineering workstation; only authorized DIGSI 5 projects/firmware loaded. **Ext. tools:** EWS removable-media GPO/device-control review; physical inspection of the front USB.	Portable/engineering media and front USB controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the relay; confirm only signed firmware + the DIGSI 5 configuration run; Web UI content is vendor read-only. **Ext. tools:** DIGSI 5 / Web UI review (no user script path).	Only trusted firmware/config runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm DIGSI 5 and HMI sessions time out on inactivity and require re-auth; the HMI returns to a locked state after timeout. **Ext. tools:** DIGSI 5 / HMI timeout config; idle-then-retry observation.	Sessions lock/timeout on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm remote DIGSI 5 / Web UI sessions can be terminated and idle sessions close; connection control limits reconnection. **Ext. tools:** DIGSI 5 / Web UI session review; Wireshark (session teardown).	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent DIGSI 5 / Web UI connections are bounded and monitored so simultaneous conflicting configuration is prevented. **Ext. tools:** DIGSI 5 connection review; Web UI session count.	Concurrent privileged sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm security-relevant actions (login, setting change, switching, firmware) are recorded in the device **non-volatile security log** and forwarded via **Syslog** to the SIEM with the acting user identity (RBAC gives per-user attribution). **Ext. tools:** DIGSI 5 (security log export); `nc -lu 514` listener / SIEM to confirm forwarding; trigger a test setting change.	Security actions logged, forwarded, and attributable.	
SR/CR 2.9	Audit storage capacity	The on-device security-log buffer is finite; forward to the SIEM (Syslog) for retention; confirm sizing and threshold alerting. **Ext. tools:** Syslog/SIEM retention review; DIGSI 5 (log buffer size).	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM alerts if Syslog forwarding fails; the device keeps local non-volatile logging so events are not silently lost. If Syslog-over-TLS is used, confirm cert validity. **Ext. tools:** SIEM (source-silent alert); DIGSI 5 (Checking the Used Syslog Servers).	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	Confirm accurate time sync in **Hardware and protocols** (SNTP / IEEE 1588 PTP / IRIG-B) so security-log and disturbance-record timestamps are accurate and correlate. **Ext. tools:** DIGSI 5 (time source config); `nmap -sU -p 123 <ntp_srv>` + Wireshark `ntp`.	Reliable, synchronized timestamps (SNTP/PTP/IRIG-B).	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: locked panel; secure the **front USB** and unused Ethernet module ports; use the relay test mode/blocking during maintenance. After commissioning, **disable the Diagnostics Homepage** (Siemens recommendation) and any unused protocol. **Ext. tools:** Physical inspection; DIGSI 5 (Diagnostics Homepage disabled; interface enable-state); `nmap -p 443 <ip>` (Homepage closed).	Physical/diagnostic interfaces controlled; Diagnostics Homepage + unused protocols disabled.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Confirm secured channels: DIGSI 5 uses mutually-authenticated TLS; Web UI uses HTTPS; enable **IEC 61850 Secure MMS** - in Hardware and protocols enable IEC 61850, then in **Network access security** set the interface to **SecureTLS (port 3782)** and **uncheck "enable non-secure mode"** so cleartext **port 102** is closed. **Test:** confirm MMS is on 3782 (TLS) and 102 is closed. **Ext. tools:** `nmap -p 102,3782 <ip>` (102 closed, 3782 open); Wireshark `mms || tls` (encrypted, no cleartext MMS).	DIGSI/Web/MMS on TLS (3782); non-secure 102 disabled; station protocols segmented.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Siemens **digitally signed firmware** runs; the relay rejects unsigned/altered firmware at load. No general code-execution path on the IED. **Ext. tools:** DIGSI 5 (firmware signature/version); cross-check the package hash vs the Siemens download portal / ProductCERT advisory.	Only signed firmware runs; component protected from malicious code.	EDR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: RBAC/connection-password state, per-interface access levels, confirmation IDs, Secure MMS (3782 / 102-off), Trusted CA, Diagnostics Homepage off, and Syslog, against the C081 baseline; compare the DIGSI 5 project. **Ext. tools:** DIGSI 5 (compare to baseline project); `nmap -p 102,3782,443 <ip>` (confirm hardened state).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm settings integrity: archive the DIGSI 5 project, use change detection, and rely on RBAC + confirmation IDs so unauthorized setting/firmware change is prevented/detected. Compare online-vs-offline settings. **Ext. tools:** DIGSI 5 (project archive + online/offline compare); change-management record.	Settings integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the relay tolerates malformed protocol frames (MMS/GOOSE/DNP3/IEC 60870) without malfunction or spurious trip. **ISOLATED only:** fuzz a representative relay on a bench and watch protection integrity - never on an in-service IED. **Ext. tools:** Protocol fuzzer (`boofuzz` / Defensics IEC 61850) on a bench relay; Wireshark; watch the relay self-supervision/alarm buffer.	No malfunction/spurious operation on malformed input.	Do NOT fuzz an in-service relay.
SR/CR 3.6	Deterministic output	Verify the machine-protection trip and comm-loss behavior is deterministic and fail-safe: confirm the configured trip logic for the generator functions (e.g. generator differential 87G, stator/rotor earth fault, over/under-excitation, reverse power 32R, over/underfrequency), blocking, and GOOSE-loss supervision so protection stays correct on comms loss. **Test:** in a test scheme, drop GOOSE / MMS and confirm the defined supervised behavior. **Ext. tools:** DIGSI 5 (protection/trip logic + GOOSE-supervision config); scheme test (planned outage).	Protection outputs deterministic and fail-safe on fault/comm loss.	
SR/CR 3.7	Error handling	Confirm graceful self-supervision handling: continuous self-monitoring raises alarms without unsafe trips or info leakage; review the diagnostic/alarm buffer. **Ext. tools:** DIGSI 5 (self-supervision / alarm buffer review).	Graceful error handling; no unsafe trip or info leak.	
SR/CR 3.8	Session integrity	Confirm DIGSI 5 / Web UI / Secure MMS sessions are integrity-protected (mutually-authenticated TLS) against replay/hijack; no unauthenticated management session path remains (102 disabled). **Ext. tools:** Wireshark (TLS session; no cleartext MMS on 102).	Management sessions integrity-protected; no unauthenticated path.	
SR/CR 3.9	Protection of audit information	Protect the security log and its Syslog transport (Syslog-over-TLS where supported) and the SIEM store; restrict who can read/clear the device log. **Ext. tools:** DIGSI 5 (log access rights); SIEM access review; confirm Syslog-over-TLS cert.	Audit records protected from unauthorized read/modify/delete.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.10	Support for updates	Update firmware only with Siemens signed firmware via DIGSI 5; the relay validates the signature; plan the update with the scheme out-of-service and a rollback to the prior signed version; track Siemens ProductCERT advisories. **Ext. tools:** DIGSI 5 (signed update/verify); Siemens ProductCERT advisory + package hash check.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the relay in a locked panel; control the front USB and rear module ports; the non-volatile security log records config/firmware/switching changes as tamper evidence; seal where required. **Ext. tools:** Physical inspection; DIGSI 5 (security-log review for unexpected changes).	Panel locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The relay accepts only Siemens-signed firmware (supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Test:** attempt to load a tampered firmware package -> rejected. **Ext. tools:** DIGSI 5 (signature verify); isolated unsigned-image attempt -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	Confirm the asset owner provisions its own **CA** (via SICAM GridPass) for DIGSI 5 client-cert trust and Secure MMS/Web UI device certs, set as the **Trusted CA** in Network access security - the asset-owner root of trust. **Ext. tools:** DIGSI 5 (Trusted CA = customer CA); SICAM GridPass (CA/enrollment); browser verify of the configured CA.	Asset-owner certificate provisioning verified.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the relay validates signed-firmware integrity before execution so only signed firmware boots; capture the firmware version/signed status. **Ext. tools:** DIGSI 5 (firmware version/signed status).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, use **Online › Security › Reset access credentials** (or the Download-credentials-reset-file flow) and factory-reset the device so settings, users, connection password, confirmation IDs, and certificates are not recoverable. **Ext. tools:** DIGSI 5 (Online › Security › Reset access credentials; factory reset).	Settings, credentials, and certificates purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for DIGSI TLS, Secure MMS (3782), Web UI HTTPS, and any Syslog-over-TLS (current suites, managed certs); disable weak/legacy and the non-secure MMS port. **Ext. tools:** `testssl.sh https://<ip>`; `openssl s_client -connect <ip>:3782`; confirm 102 disabled.	Modern crypto in use; weak/legacy + non-secure port disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the relay sits in a controlled substation zone behind the station firewall; station-bus (61850) and engineering traffic segmented from IT/WAN; only required protocols (MMS 3782, DNP3, IEC 60870) cross defined conduits. **Ext. tools:** `nmap -p 102,3782,443,20000,2404 <ip>` from each zone; firewall/ACL rule review.	Relay in a segmented zone; only required protocols cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose protection IED with no general-purpose person-to-person communications. **Ext. tools:** Confirm no such services on the relay.	N/A - justification recorded (single-purpose embedded device).	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose IED; no separable general-purpose applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm the security log and disturbance/event records are readable/exportable via DIGSI 5 and forwarded via **Syslog** to the SIEM; the substation LAN is passively monitored (OT IDS on a mirror port). **Ext. tools:** DIGSI 5 export; `nc -lu 514` listener + SIEM; passive OT IDS (Nozomi/Dragos) on a SPAN port.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the relay tolerates network storms/scan floods without losing protection (SIPROTEC 5 network robustness); station-firewall rate controls limit floods. Monitor CPU/comms health while testing on a bench. **Ext. tools:** ISOLATED bench: `hping3 --flood -p 102 <ip>` / GOOSE storm; watch relay health + protection integrity.	Protection continues under network load; resources bounded.	
SR/CR 7.2	Resource management	Confirm the relay bounds communication/session resources so a single protocol/service cannot starve the protection function (protection has priority by design). **Ext. tools:** DIGSI 5 (comms/session limits); bench load test with health monitoring.	Resources bounded; protection unaffected by service load.	
SR/CR 7.3	Control system backup	Confirm the DIGSI 5 project (settings, config, certificates where applicable) is backed up (versioned, offline) and a restore to a spare relay is tested for a known-good rebuild. **Ext. tools:** DIGSI 5 project backup repository; restore test on a spare relay.	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden per the C081 manual: activate RBAC / set the connection password + confirmation IDs; set per-interface access levels (Network access security); enable Secure MMS (3782) and disable non-secure 102; **disable the Diagnostics Homepage** and any unused protocol/port; set time-sync securely. **Ext. tools:** DIGSI 5 (Safety and security / Hardware and protocols config); `nmap -p 102,3782,443,20000,2404 <ip>` (only required reachable).	Least functionality; unused protocols/services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.8	Component inventory	Confirm the relay (type 7UM85, firmware version, communication modules, DIGSI 5 version) is inventoried so vulnerabilities track against **Siemens ProductCERT** advisories (SIPROTEC/DIGSI CVEs). **Ext. tools:** DIGSI 5 device inventory; Siemens ProductCERT feed; passive OT IDS inventory.	Accurate component/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
DIGSI 5	Native security & config review (all FRs)	Project tree › [device] › Safety and security: Operations safety and access control (RBAC / connection password / confirmation IDs); Network access security (per-interface access level + Trusted CA); Hardware and protocols (IEC 61850 SecureTLS, time sync); Online › Security (credential reset). Export the project as the baseline.	Read/authorized project copy.
On-device HMI	Local access review (1.1, 2.1, 2.5)	Confirm HMI login/lock, access levels, and confirmation-ID prompts at the panel.	Physical; authorized.
Web UI / Diagnostics Homepage	Browser access & hardening (1.1, 1.8, 2.13, 7.6)	Confirm login + HTTPS with a managed cert; download the CSR for Secure-MMS enrollment; confirm the Diagnostics Homepage is disabled after commissioning.	Read-only; authorized.
nmap	Protocol/port exposure & segmentation (1.1, 1.13, 3.1, 5.x, 7.6)	`nmap -p 102,3782,443,20000,2404 <ip>` - confirm 3782 open, 102 closed, Homepage/DNP3/104 only where required; scan per zone to prove segmentation.	Read-only; authorized.
openssl / testssl.sh	TLS strength on MMS/Web (1.8, 1.9, 4.3)	`openssl s_client -connect <ip>:3782 | openssl x509 -noout -issuer -dates`; `testssl.sh https://<ip>` for suites/cert grade.	Non-intrusive.
Syslog listener + SIEM	Security-event forwarding (2.8-2.10, 6.x)	`nc -lu 514` to confirm the relay forwards security-log events; trigger a test login/setting change and confirm receipt; verify Syslog-over-TLS cert if used.	Coordinate with SIEM team.
Wireshark / tcpdump	Comms integrity & identity (1.2, 3.1, 3.8)	SPAN/tap the station bus; filter `mms || goose || tls` to confirm Secure MMS (3782/TLS), no cleartext 102, IED names, and time sync.	Passive; SPAN/tap only.
Protocol fuzzer / hping3	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` / Defensics IEC 61850 on a bench relay; `hping3 --flood -p 102 <ip>` storm; watch protection integrity + self-supervision.	ISOLATED bench; never in-service; written authorization.
Siemens ProductCERT / SICAM GridPass	Vuln tracking & PKI (1.8, 3.10, 3.13, 7.8)	Track SIPROTEC 5 / DIGSI 5 advisories + required firmware; issue/sign DIGSI 5 client and device certificates with SICAM GridPass.	Reference / PKI ops.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.